

Olasentra Event Staff System — Production Audit Report

Date: 2026-06-06 | **Scope:** olasentra.com ecosystem | **Stack:** Custom PHP 8.x + MySQL

Executive Summary

Live production is **operational**: health API reports DB/storage OK; Nick Cave event shows 36 registrations (35 approved). Critical staff-list bug (empty "All roles" filtering to DSP only) was fixed.

This audit applied safe hardening without removing business functionality. High-priority items remain: apply admin CSRF, registrant API rate limits, migration pipeline.

A. Critical Issues

#	Issue	Status
1	Staff list "All roles" silently filtered staff_role=dsp	Fixed
2	Unauthenticated DB diagnostic database/tmp-venue-check.php	Quarantined + blocked
3	Dev scripts under /scripts/ web-accessible	Blocked + quarantined
4	api/registrant-lookup.php returns PII by email only	Open — add rate limit
5	apply/admin/update-details.php weak upload validation	Open
6	Apply admin has no CSRF on POST forms	Open

B. Bugs Fixed

- Role filter bug — normalizeStaffRole("") returned dsp
- Staff pagination — 50/page, per-page selector
- Diagnostic exposure — quarantined to storage/quarantine/2026-06-06-audit/
- Apache hardening — deny database/, scripts/, vendor/
- Upload directory — uploads/.htaccess blocks script execution
- roster-check API — diagnostics hidden on production

C. Security Issues

Fixed / mitigated

- Root .htaccess blocks includes/, storage/, database/, scripts/, vendor/
- config.php denied via FilesMatch
- Main admin: CSRF, login logout, capability-based auth
- PDO prepared statements; EMULATE_PREPARES false in production

Remaining (prioritized)

Priority	Item
HIGH	Add CSRF tokens to apply admin
HIGH	Harden apply/admin/update-details.php uploads
HIGH	Set explicit APPLY_SSO_SECRET / cron keys
HIGH	Rate-limit api/registrant-lookup.php
MEDIUM	Apply admin: initSecureSession()
MEDIUM	Convert GET state changes to POST+CSRF
LOW	Remove import-summer-roster.php after import

D. Performance Issues

Item	Recommendation
Staff list grouped queries	Fixed JOIN removal in count query
Missing composite indexes	Add (event_id, status) on staff_registrations
LOWER(email) in WHERE	Normalize emails at insert
Runtime ensure*Schema()	Consolidate migrations 35–47

E. Database Issues

Healthy

- FK staff_registrations.event_id → events
- UNIQUE (email, event_id)
- Production: 36 registrations event #1 Nick Cave (35 approved)

Recommendations

1. Extend getDatabaseMigrationFiles() to phases 35–47
2. Add FKs: staff_messages.staff_id, personal_invoice_lines, saved_job_records.event_id
3. Backfill NULL staff_registrations.staff_id
4. Periodic reconciliation: staff vs latest registration per email

F. Files Safe to Remove (after review)

Path	Notes
storage/backups/pre-deploy-*.zip (keep latest 3)	Deploy artifacts
import-summer-roster.php	After roster import
database/seed-*.php, database/tmp-*	Dev only

G. Files Requiring Review

Path	Reason
api/registant-lookup.php	PII in JSON response
apply/admin/update-details.php	Public profile + uploads
cron/daily-cleanup.php	Web-accessible with key
admin/import-roster.php	GET-triggered import

H. Changes Made (2026-06-06)

File	Change
.htaccess	Block database/scripts/vendor; HTTPS redirect
database/.htaccess, scripts/.htaccess	Deny all web access
uploads/.htaccess	Block script execution
api/roster-check.php	Hide verbose diagnostics in production
includes/staff-repository.php	Role filter fix
admin/staff.php	Pagination + event flat list

I. Remaining Recommendations

Immediate

- 1. Run Admin → Backups → Full backup on production
- 2. Confirm APP_ENV=production in server config.php
- 3. Set apply SSO/cron secrets in sso.local.php
- 4. Add composite index (event_id, status)

Short term (1–2 weeks)

- 1. CSRF middleware for apply admin
- 2. Rate limit registrant lookup (10 req/min/IP)
- 3. Complete migration runner phases 35–47

J. Final Verification Checklist

Test	Expected
Admin login	admin.olasentra.com/login.php
Staff list event filter	36 rows for Nick Cave, all roles
Registration form	register.olasentra.com
Health API	JSON ok
Blocked paths	/database/setup.php → 403/404